



Introduction to Information Security Management

Part 1

The History of Information Security

- Computer security **began** immediately after the first **mainframes were developed**
 - Groups developing code-breaking computations during World War II created the first modern computers
 - **Multiple levels** of security were implemented
- **Physical controls** to **limit access to sensitive military locations to authorized personnel**
- Rudimentary in defending against physical theft, espionage, and sabotage

Date	Documents
1968	Maurice Wilkes discusses password security in <i>Time-Sharing Computer Systems</i> .
1973	Schell, Downey, and Popek examine the need for additional security in military systems in "Preliminary Notes on the Design of Secure Military Computer Systems." ⁵
1975	The Federal Information Processing Standards (FIPS) examines Digital Encryption Standard (DES) in the <i>Federal Register</i> .
1978	Bisbey and Hollingworth publish their study "Protection Analysis: Final Report," discussing the Protection Analysis project created by ARPA to better understand the vulnerabilities of operating system security and examine the possibility of automated vulnerability detection techniques in existing system software. ⁶
1979	Morris and Thompson author "Password Security: A Case History," published in the Communications of the Association for <i>Computing Machinery</i> (ACM). The paper examines the history of a design for a password security scheme on a remotely accessed, time-sharing system.
1979	Dennis Ritchie publishes "On the Security of UNIX" and "Protection of Data File Contents," discussing secure user IDs and secure group IDs, and the problems inherent in the systems.
1984	Grampp and Morris write "UNIX Operating System Security." In this report, the authors examine four "important handles to computer security": physical control of premises and computer facilities, management commitment to security objectives, education of employees, and administrative procedures aimed at increased security. ⁷
1984	Reeds and Weinberger publish "File Security and the UNIX System Crypt Command." Their premise was: "No technique can be secure against wiretapping or its equivalent on the computer. Therefore no technique can be secure against the systems administrator or other privileged users ... the naive user has no chance." ⁸

Key Dates for Seminal Works in Early Computer Security

The 1990s

- **Networks** of computers became more common; so too did the **need to interconnect networks**
- **Internet** became first manifestation of a global network of networks
- Initially based on de facto standards
- In **early Internet** deployments, **security was treated as a low priority**

2000 to Present

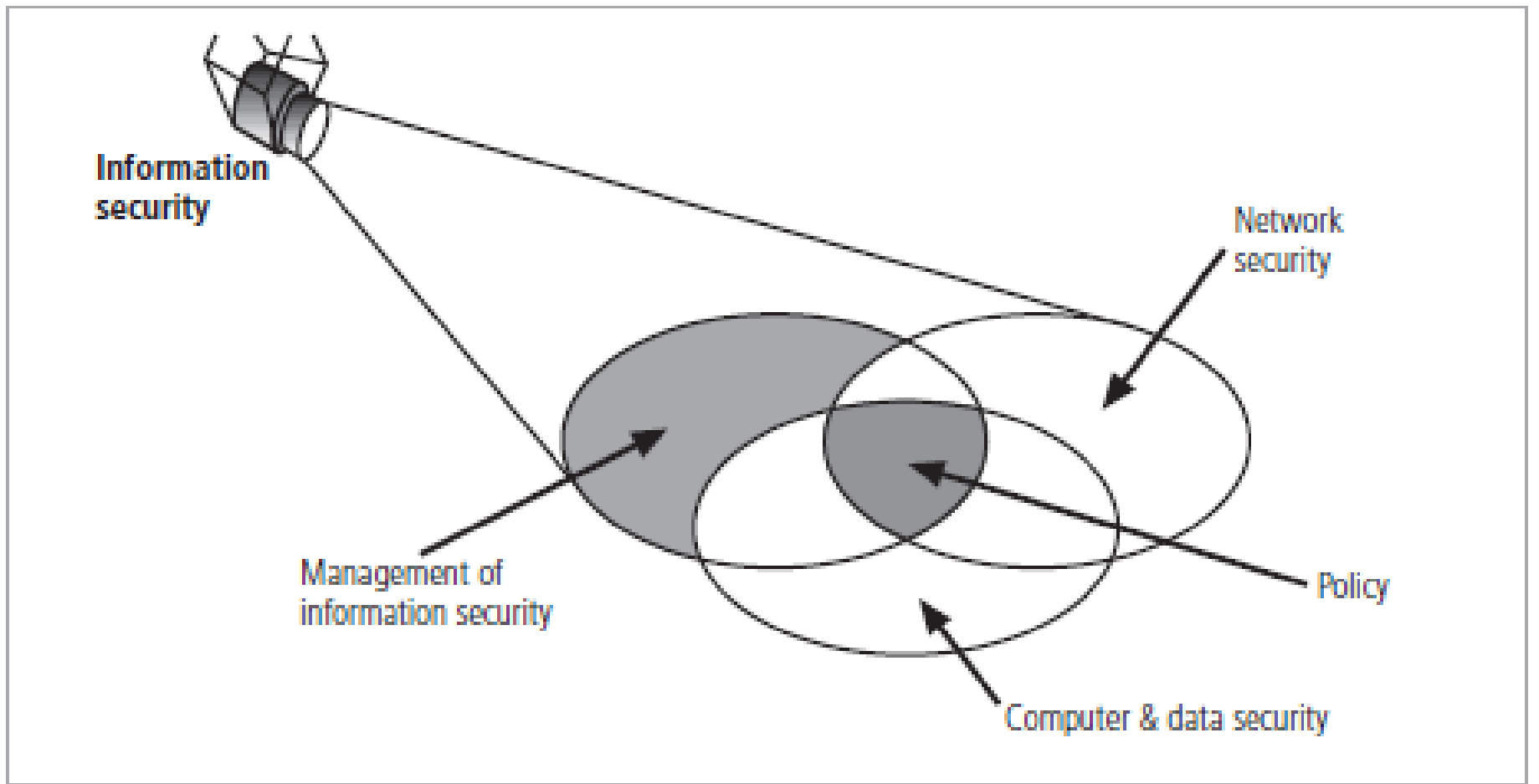
- The Internet **brings millions of computer networks into communication** with each other—many of them unsecured
- Ability to secure a computer's data influenced by the **security of every computer to which it is connected**
- **Growing** threat of **cyber attacks** has increased the **need for improved security**

What is Security?

- “**The quality or state of being secure to be free from danger**”
- A successful organization should **have multiple layers of security** in place:
 - **Physical** security
 - **Personal** security
 - **Operations** security
 - **Communications** security
 - **Network** security
 - **Information** security

What is Security? (cont'd.)

- The **protection** of **information** and its critical **elements**, including **systems** and **hardware** that **use**, **store**, and **transmit** that information
- **Necessary tools:** **policy**, **awareness**, **training**, **education**, **technology**
- **C.I.A. triangle**
 - Was standard based on **confidentiality**, **integrity**, and **availability**
 - Now **expanded** into **list of critical characteristics of information**

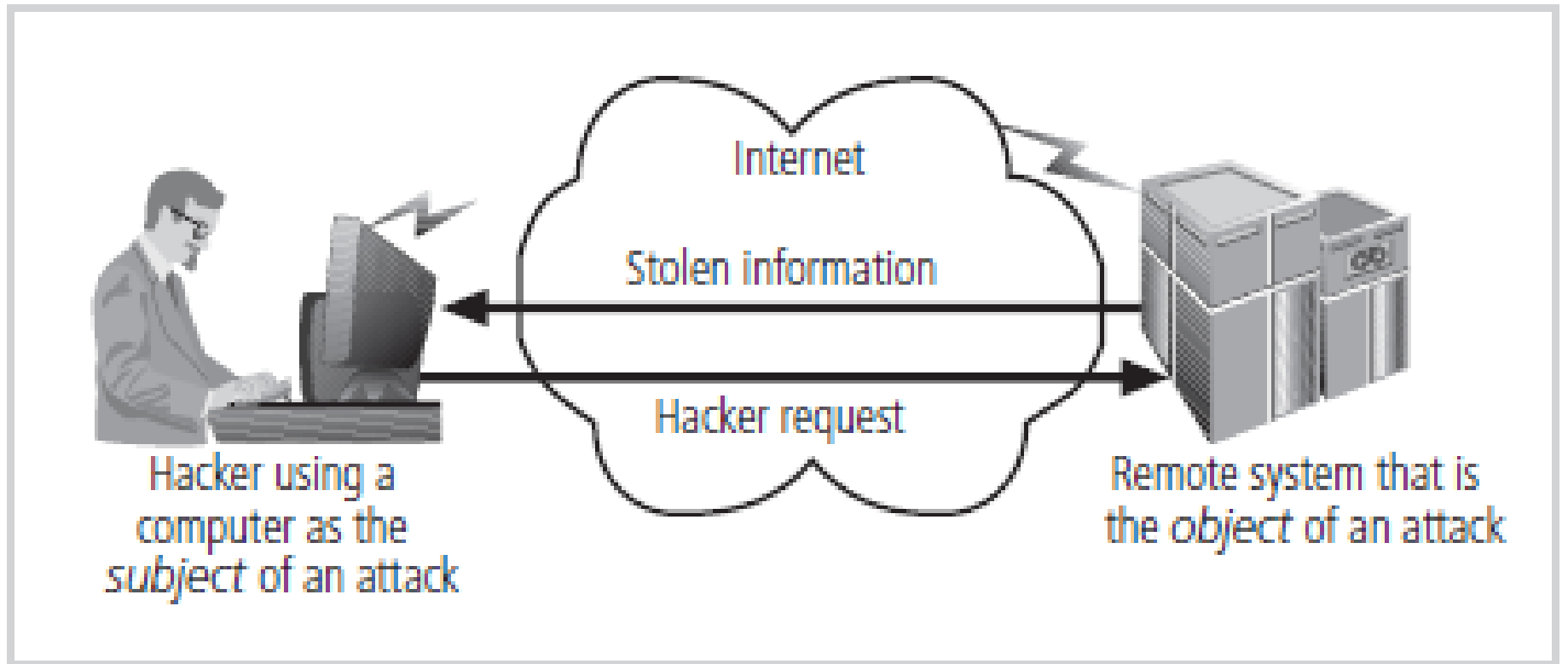


Components of Information Security

Key Information Security Concepts (cont'd.)

- **Computer** can be **subject** of an attack and/or the **object** of an attack
 - When the **subject of an attack**, computer is used as an **active** tool to conduct attack
 - When the **object of an attack**, computer is the entity **being attacked**

Subject and Object of Attack



Computer as the Subject and Object of an Attack

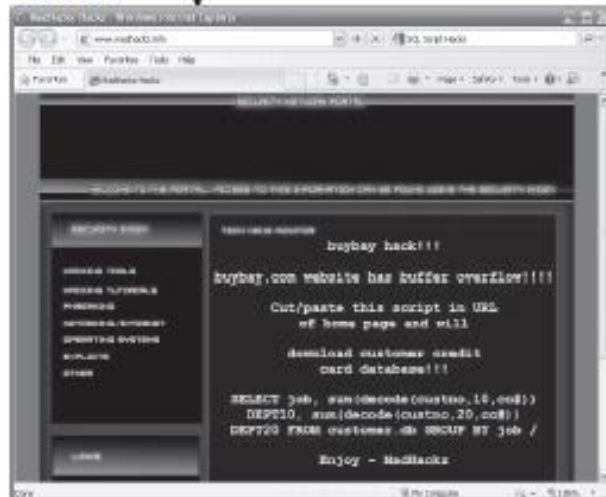


Threat: Theft
Threat agent: Ima Hacker

Exploit: Script from MadHackz
 Web site



Vulnerability: Buffer
 overflow in online
 database Web interface



Attack: Ima Hacker downloads *exploit* from MadHackz web site, then accesses buybay's Web site and applies script, resulting in **loss:** download of customer data

Asset: buybay's
 customer database

Customer data dump for buybay.com											
ID	CardNo	First	M.I.	MoWB	Street	City	State	Zip	Country	Type	Member
1	0001	John	A	123 Argonne	Albany	GA	31704	354	USA	Owner	123456789
2	0002	Jane	B	456 Argonne	Albany	GA	31704	354	USA	Owner	123456789
3	0003	John	C	789 Argonne	Albany	GA	31704	354	USA	Owner	123456789
4	0004	Jane	D	101 Argonne	Albany	GA	31704	354	USA	Owner	123456789
5	0005	John	E	122 Argonne	Albany	GA	31704	354	USA	Owner	123456789
6	0006	Jane	F	143 Argonne	Albany	GA	31704	354	USA	Owner	123456789
7	0007	John	G	164 Argonne	Albany	GA	31704	354	USA	Owner	123456789
8	0008	Jane	H	185 Argonne	Albany	GA	31704	354	USA	Owner	123456789
9	0009	John	I	206 Argonne	Albany	GA	31704	354	USA	Owner	123456789
10	0010	Jane	J	227 Argonne	Albany	GA	31704	354	USA	Owner	123456789
11	0011	John	K	248 Argonne	Albany	GA	31704	354	USA	Owner	123456789
12	0012	Jane	L	269 Argonne	Albany	GA	31704	354	USA	Owner	123456789
13	0013	John	M	290 Argonne	Albany	GA	31704	354	USA	Owner	123456789
14	0014	Jane	N	311 Argonne	Albany	GA	31704	354	USA	Owner	123456789
15	0015	John	O	332 Argonne	Albany	GA	31704	354	USA	Owner	123456789
16	0016	Jane	P	353 Argonne	Albany	GA	31704	354	USA	Owner	123456789
17	0017	John	Q	374 Argonne	Albany	GA	31704	354	USA	Owner	123456789
18	0018	Jane	R	395 Argonne	Albany	GA	31704	354	USA	Owner	123456789
19	0019	John	S	416 Argonne	Albany	GA	31704	354	USA	Owner	123456789
20	0020	Jane	T	437 Argonne	Albany	GA	31704	354	USA	Owner	123456789

Information Security Terms

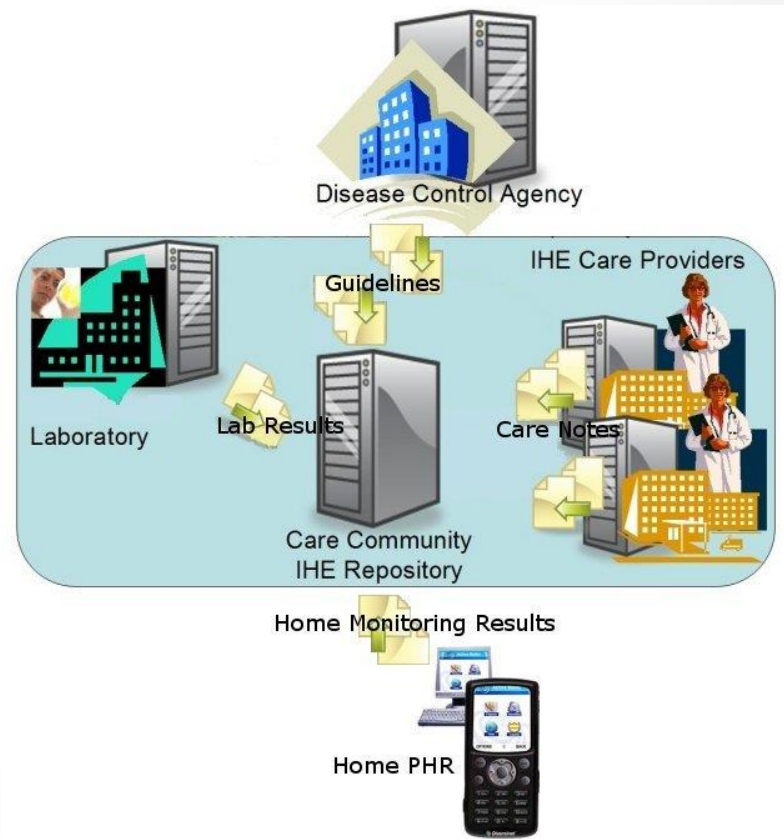
Critical Characteristics of Information

- The value of information comes from the characteristics it possesses:
 - Availability
 - Accuracy
 - Authenticity
 - Confidentiality
 - Integrity
 - Utility

Components of an Information System

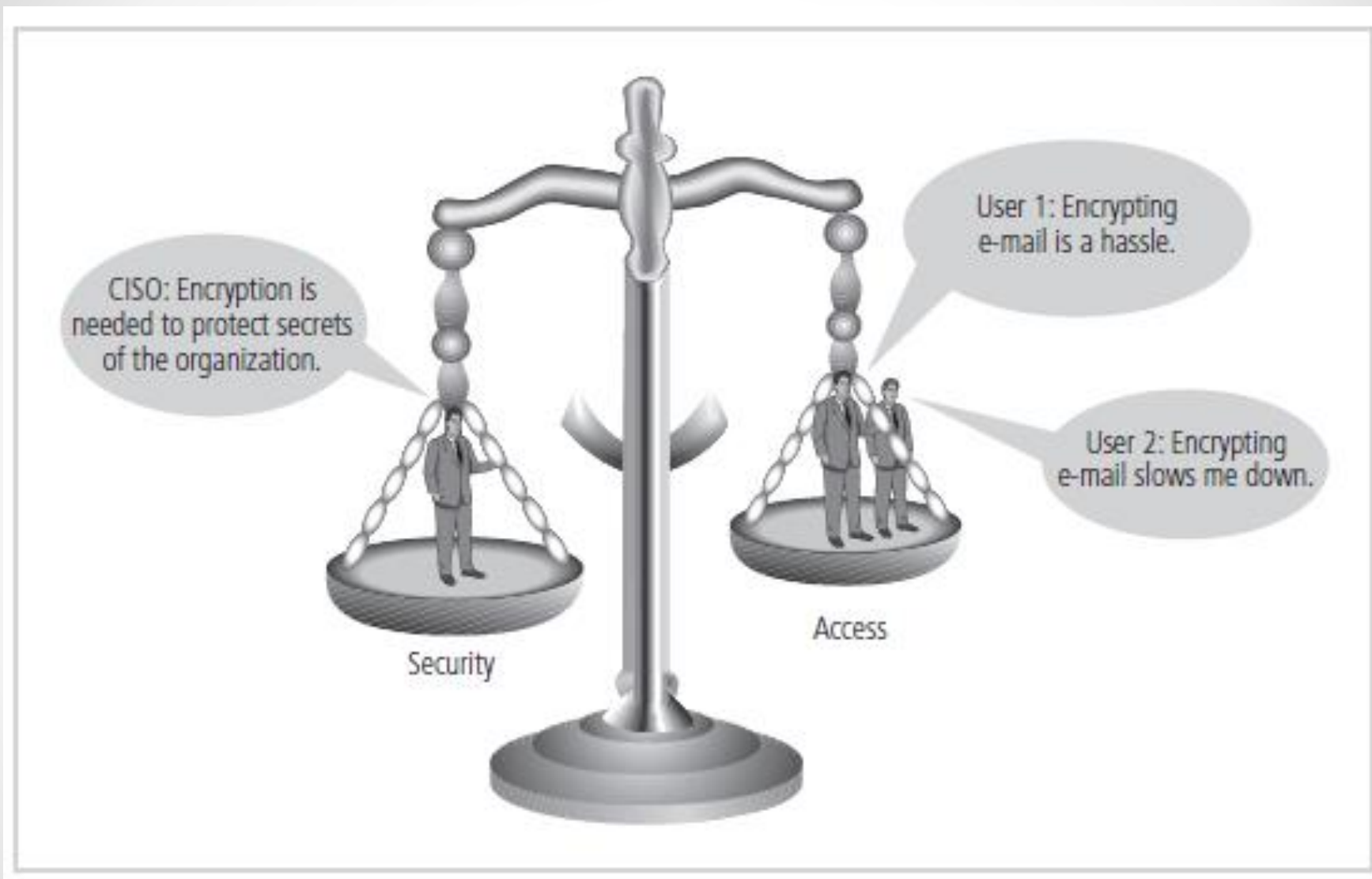
- **Information system** (IS) is entire **set of components** necessary to use information as a resource in the **organization**

- Software
- Hardware
- Data
- People
- Procedures
- Networks



Balancing Information Security and Access

- Impossible to obtain perfect security—it is a process, not an absolute
- **Security should be considered balance** between protection and availability
- To achieve **balance**, level of security must allow reasonable access, yet protect against threats



Balancing Information Security and Access

Why is Information Security Important?

Information Security is essential because of the following reasons:

- **Data Protection:** Safeguarding personal, financial, and confidential business information.
- **Business Continuity:** Protecting businesses from attacks that could disrupt operations.
- **Preventing Financial Loss:** Cyberattacks can result in significant financial losses.
- **Preserving Reputation:** A cyberattack can damage an organization's reputation.
- **Legal Requirements:** Many industries are regulated and required to meet certain cybersecurity standards.

Security Professionals and the Organization

- **Wide range of professionals** required to **support** a diverse **information security program**
- **Senior management** is key component
- Additional **administrative support** and **technical expertise** are required to **implement details of IS program**

Senior Management

- **Chief Information Officer (CIO)**
 - Senior technology officer
 - Primarily responsible for advising senior executives on strategic planning
- **Chief Information Security Officer (CISO)**
 - Primarily responsible for **assessment, management, and implementation of IS** in the organization
 - **Usually reports directly** to the CIO

Information Security Project Team

- **A number of individuals who are experienced in one or more facets of required technical and nontechnical areas:**
 - Champion: : A senior executive who promotes the project and ensures its support, both financially and administratively
 - Team leader
 - Security policy developers: who understand the organizational culture, policies, and requirements for developing and implementing successful policies
 - Risk assessment specialists: understand financial risk assessment techniques, the value of organizational assets, and the security methods to be used
 - Security professionals
 - Systems administrators
 - End users

Data Responsibilities

- **Data owner:** responsible for the **security and use** of a particular set of information
- **Data custodian:** responsible for **storage, maintenance, and protection** of information
- **Data users:** end users who **work with information** to **perform their daily jobs** supporting the mission of the organization

Communities of Interest

- Group of individuals united by similar interests/values within an organization
 - **Information security management and professionals**
 - **Information technology management and professionals**
 - **Organizational management and professionals**

Information Security: Is it an Art or a Science?

- **Implementation** of information security often described as **combination of art and science**
- “Security artisan” idea: based on the way individuals perceive systems technologists since computers became commonplace

Security as Art

- **No hard and fast** rules nor many universally accepted complete solutions
- **No manual** for implementing security through entire system

Security as Science

- **Dealing with technology** designed to operate at high levels of performance
- Specific **conditions** cause virtually all actions that occur in computer systems
- Nearly every fault, security hole, and systems malfunction are a result of **interaction of specific hardware and software**
- If developers had sufficient time, they **could resolve and eliminate faults**

Security as a Social Science

- Social science **examines the behavior of individuals interacting with systems**
- Security **begins and ends with the people that interact with the system**
- Security administrators can greatly reduce levels of risk caused by end users, and create more acceptable and supportable security profiles

What Is Information Security?

- Knowing why information security is important today and who the attackers are is beneficial

Defining Information Security

- **Security** can be considered as a **state of freedom from a danger or risk**
 - This state or condition of freedom exists **because protective measures are established and maintained**
- **Information security**
 - **The tasks of guarding information that is in a digital format**
 - Ensures that **protective measures are properly implemented**
 - **Cannot** completely **prevent attacks or guarantee that a system is totally secure**

Defining Information Security (continued)

- **Information security** is intended to **protect information that has value to people and organizations**
 - This value comes from the characteristics of the information:
 - **Confidentiality**
 - **Integrity**
 - **Availability**
- Information security is **achieved** through a **combination of three entities**

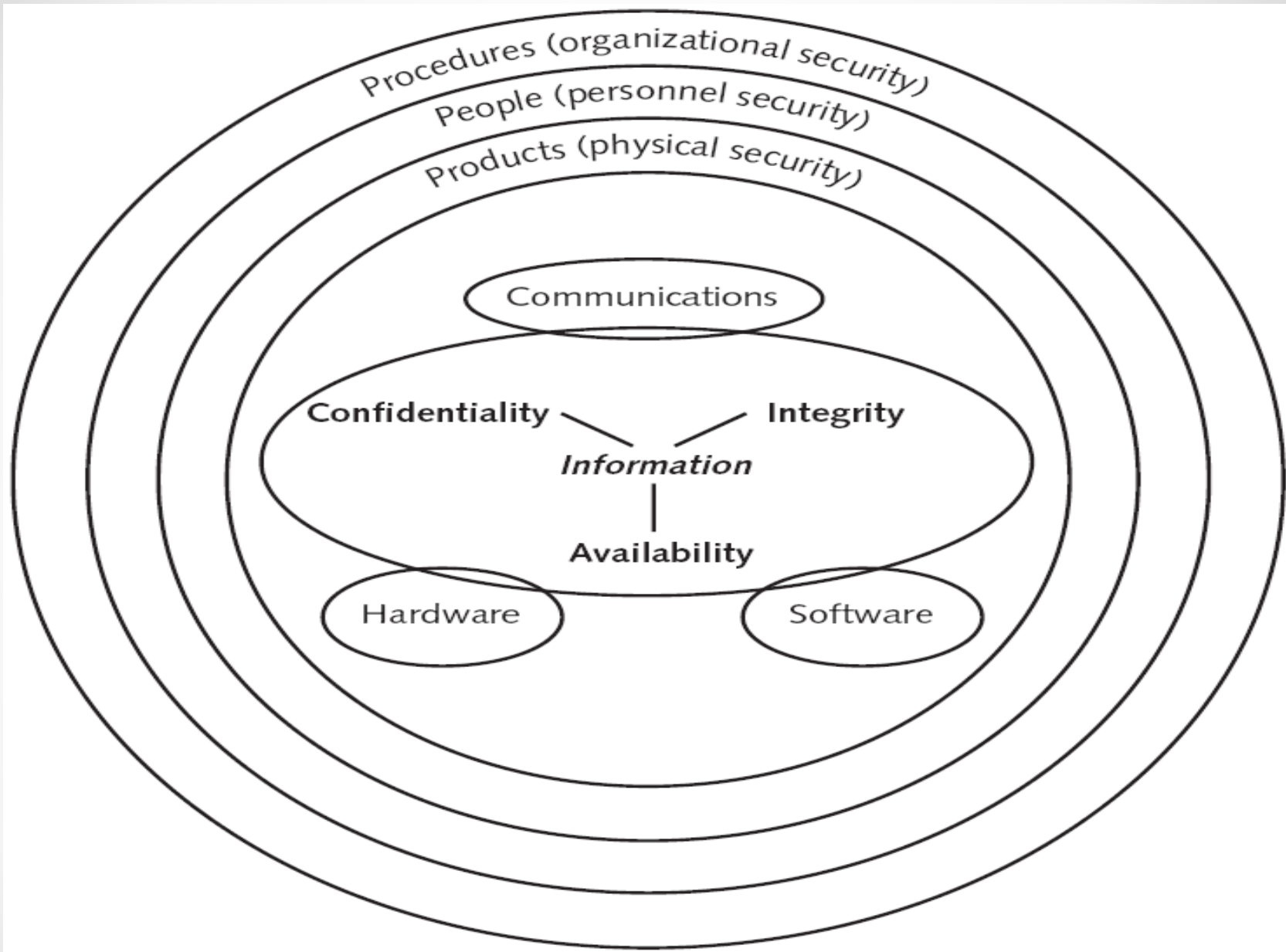


Figure 1-3 Information security components

Defining Information Security (continued)

Layer	Description
Products	The physical security around the data. May be as basic as door locks or as complicated as intrusion-detection systems and firewalls.
People	Those who implement and properly use security products to protect data.
Procedures	Plans and policies established by an organization to ensure that people correctly use the products.

Table 1-3 Information security layers

Defining Information Security (continued)

- A more comprehensive definition of information security is:
 - *That which **protects the integrity, confidentiality, and availability of information on the devices that store, manipulate, and transmit the information through products, people, and procedures***

Information Security Terminology

- **Asset**
 - **Something** that has a value
- **Threat**
 - An **event or object** that may defeat the security measures in place and result in a loss
- **Threat agent**
 - A **person or thing** that has the power to carry out a threat

Information Security Terminology (continued)

- **Vulnerability**
 - **Weakness** that allows a threat agent to bypass security
- **Risk**
 - The **likelihood** that a threat agent will exploit a vulnerability
 - Realistically, risk cannot ever be entirely eliminated

Information Security Terminology (continued)

Risk: Stolen car radio

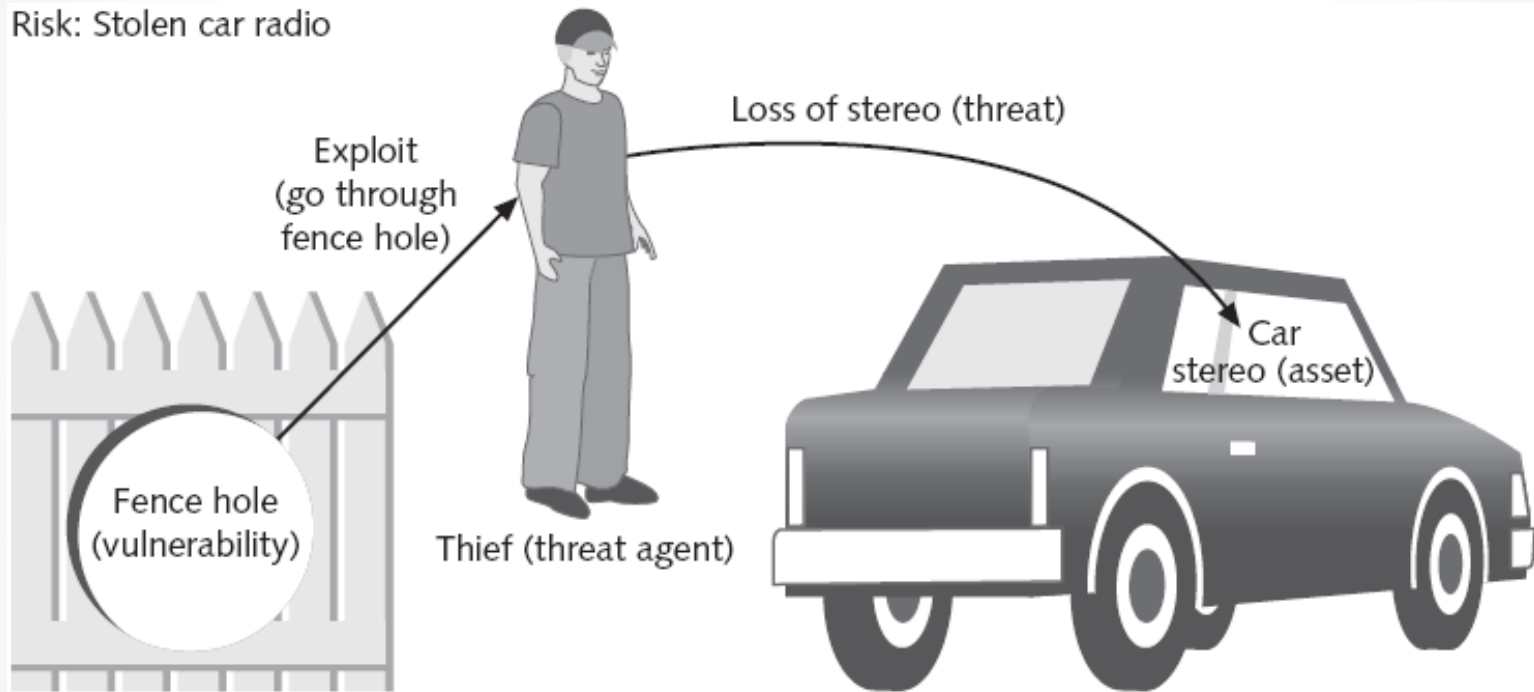


Figure 1-4 Amanda's car stereo

Information Security Terminology (continued)

Term	Example in Amanda's Scenario	Example in Information Security
Asset	Car stereo	Employee database
Threat	Steal stereo from car	Steal data
Threat agent	Thief	Attacker, virus, flood
Vulnerability	Hole in fence	Software defect
Exploit	Climb through hole in fence	Send virus to unprotected e-mail server
Risk	Transfer to insurance company	Educate users

Table 1-4 Security information terminology

Information Security (InfoSec)

Information Security (InfoSec) focuses on protecting **all types of information**, whether in **digital**, **physical**, or **intellectual** form, from unauthorized access, misuse, destruction, or alteration. Its goal is to preserve the **confidentiality**, **integrity**, and **availability** (**CIA**) of information.

Main Focus: InfoSec encompasses both physical security (e.g., protecting server rooms, locking file cabinets) and technical security (e.g., **encryption**, **access controls**).

Cyber Security

Cybersecurity is a **subset** of information security, but it focuses specifically on protecting **digital systems and data** from cyberattacks. It involves securing computers, networks, servers, and data from breaches, hacks, or malicious attacks that occur in the digital realm.

Information Security Vs. Cyber Security

Key Differences

Aspect	Information Security (InfoSec)	Cybersecurity
Scope	Broad; focuses on all forms of information (digital and non-digital)	Narrower; focuses on securing digital systems and networks
Focus	Protecting the confidentiality, integrity, and availability of all types of information	Protecting systems, networks, and data from cyberattacks
Examples	Physical document security, legal protections for IP	Network firewalls, antivirus software, encryption
Threats Addressed	Physical theft, accidental loss, unauthorized access	Hacking, phishing, malware, denial-of-service attacks
Involves	Physical security, legal controls, digital security	Primarily technical and digital controls

OSI (open System interconnection) security architecture

- consider 3 aspects of information security:
 - **security attack**
 - **security mechanism**
 - **security service**

The **OSI (open System interconnection) security architecture** focuses on security attacks, mechanisms, and services. These can be defined briefly as follows:

- **Security attack:** Any **action** that compromises the security of information owned by an organization.
- **Security mechanism:** A **process** (or a device incorporating such a process) that is designed to **detect, prevent, or recover** from a security attack.
- **Security service:** A **processing or communication service** that **enhances the security of the data processing systems and the information transfers of an organization.**
 - The services are intended to **counter security attacks**, and they make **use of one or more security mechanisms** to provide the service.

Information Security Careers Meet the Needs of Business

- **To support business operations** a number of common positions and career opportunities are needed
 - Security administrators
 - Access coordinators
 - Security architects and network engineers
 - Security consultants
 - Security testers

Key Roles in Information Security

- **Security Analyst:** Monitors and investigates security incidents and threats.
- **Security Engineer:** Designs and implements security solutions.
- **Penetration Tester (Ethical Hacker):** Simulates attacks to find weaknesses before malicious actors do.
- **Chief Information Security Officer (CISO):** Oversees an organization's entire cybersecurity strategy.
- **Incident Responder:** Responds to cybersecurity incidents and works to contain and mitigate damage.

Title	Position in Organization	Responsibilities	Average Salary
Chief Information Security Officer (CISO)	Reports directly to the CIO (large organizations may have more layers of management between); other titles "Manager for Security" and "Security Administrator"	The assessment, management, and implementation of security	\$140,000
Security manager	Reports to CISO and supervises technicians, administrators, and staff	Work on tasks identified by CISO and resolves issues identified by technicians; requires understanding of configuration and operation but not necessarily technical mastery	\$75,000
Security administrator	Between security manager and security technician	Has both technical knowledge and managerial skills; manages daily operations of security technology; may analyze and design security solutions within a specific entity; identifies users' needs	\$64,000
Security technician	Generally entry-level position with technical skills	Provide technical support to configure security hardware, implement security software, diagnose and troubleshoot problems; focus on major security technology group	\$40,000

Table 1-7 Information security positions

Information Security Principles

- **Least Privilege:** Users should have the minimum level of access necessary to perform their duties.
- **Separation of Duties:** Dividing tasks and privileges so that no single individual has control over all aspects of a critical function.
- **Defense in Depth:** Using multiple security controls to protect against threats.
- **Zero Trust:** No one, whether inside or outside the network, should be trusted by default.
- **Security by Design:** Security measures should be incorporated into systems from the ground up.